Une autre options que l'on peux appliquer est le Payload Processing permettant d
déterminer des règles de fuzzing sur la liste de mot chargé (Ex ignorer les mots av
point devant avec l'option skip if match regex et le regex adéquat ou encore rajou
ter un . html devant tout les mots à tester)
On peu ensuite activer ou desactiver tel encoding du payload dans Payload Encodin
Ensuite dans la partie Parametres Settings du payload on a de nombreuses optio
de personalisation comme l'options Grep - Math qui permet de marquer des requêt
spécifiques en fonctions de leurs reponses (Ex: 200 OK) n'oublions pas de dans ce
cas desactiver Exclude HTTP Headers
Nous pouvons une fois configuration terminé appuyer sur: Start Attack.

Fuzzing Web - ZAP Fuzzer:

Un fuzzer puissant pour diverses points de terminaisons web, pour commencer
configurer une attaque: clic droit sur la requête ciblée puis on selectionne (Attaquer.
Generer du bruit) ce qui ouvrira la fenêtre fuzzer. Ensuite on à l'option Fuzz Lo
on, son fonctionnement est similaire à Burp on selection la ou fuzzer et l'on app
sur add le mot sera alors coloré... Les charges utiles sont conceptuellement simi
aire aux payloads de Burp expliquons en trois types:
File: pour selectionner une wordlist à partir d'un fichier
File Fuzzers: pour selectionner une wordlist à partir de la base de donnée intégré
l'outil.
Numberzz: génère une séquences de nombres avec des incréments personalizés.
On peux evidement rajouter des processeurs à notre payload (ex: postfix en .php)
fonctionnement est similaire a Burp avec un petit bouton Generate Preview qui
fais plaisir. Ensuite on peux regler dans l'onglet Options quelques parametre co
me le nombre de threads notons deux mode:
Depth First: tout les mots sur une position avant de passer à la suivante
Breadth First: chaque mot sur toute les positions avant de passer au suivant
Ensuite on peu lancer le scan en appuyant sur Start Fuzzer on peux egalemen
trier les responses par code de retour.

Web Scanner - Burp Scanner:

Le scanner de Burp est une fonctionnalité de la version Pro donc payante, il
lise un crawler pour cartographier le site web. Il dispose d'un scan passif et actif
et une gestion du scope d'attaque bien organisée ainsi que d'un export structu
des resultats finaux du scan...

Web Scanner - ZAP Scanner:

Sur ce soit dans le HUD ou dans le menu attaque on a un spider similaire
crawler de Burp, on a un static (suit les lien) et un dynamique le AJAX Spid
(clic sur les boutons, remplis formulaire, etc)
Le spider effectue automatiquement un scan passif en parallèles générant si il y à
lieu des alertes consultables
Une fois cela terminé on peux également lancer un scan actif / Δ au nombre de req
etes et aux ban générées dès qu'il y a beaucoup de requêtes)
Encore une fois les alertes générées par le scan son consultables notons que souvent
les high sont celle qui touchent la backend.
Enfin on peu générer un rapport en HTML - XML ou Markdown, ces rapport ne
doivent jamais être servi tels quelles au client ce sont juste des "pièces jointes
supplementaires...

Il est également interessant de noter que Burp et ZAP possèdent tout deux des
"magasin" d'extension souvent developpés par la communauté pouvant s'averer
utiles selon nos besoins spécifiques